

Task 8

Tools Used:

- Kali Linux
 - John the Ripper
 - rockyou.txt wordlist
 - OpenSSL
-

Objective

To gain hands-on experience with cracking password hashes using John the Ripper (JTR), and understand the implications of weak password storage, hashing, and cracking methodologies used by attackers.

Procedure

1. John Installation (Kali Linux):

John the Ripper was already pre-installed on Kali Linux. However, to ensure the latest version, the following command was run:

```
sudo apt update && sudo apt install john
```

2. Creating a Sample Hash:

A sample password "mypassword123" was hashed using MD5 with OpenSSL:

```
echo -n 'mypassword123' | openssl passwd -1 -stdin
```

Output:

```
$1$12345678$AvuWqQGvO/yMR1Jh8Kj0Z1
```

3. Saving the Hash to a File:

A formatted hash was saved to a file called `hash.txt`:

```
testuser:$1$12345678$AvuWqQGvO/yMR1Jh8Kj0Z1
```

4. Running John the Ripper:

John was then run with the `rockyou.txt` wordlist to crack the password:

```
john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
```

5. Viewing the Cracked Password:

After a short while, the cracked password was displayed using:

```
john --show hash.txt
```

Output:

```
testuser:mypassword123:1:1:Test User:/home/testuser:/bin/bash
```

Findings

- **Password Cracked:** `mypassword123`
- **Hash Type Identified:** MD5-Crypt (identified automatically by John)
- **Time Taken:** ~5 seconds (due to weak password and common wordlist)
- **Wordlist Used:** `rockyou.txt` (commonly used list of real-world leaked passwords)

Learning Outcomes

- Learned how password hashing (specifically MD5-Crypt) works.
- Understood the importance of using salts in password hashes to prevent rainbow table attacks.

- Understood how dictionary attacks differ from brute force attacks.
 - Saw how fast weak passwords can be cracked with common wordlists.
 - Gained hands-on experience with one of the most widely-used password cracking tools in ethical hacking.
-

Analysis & Recommendations

1. Password Strength:

- The cracked password was weak and easily found in the rockyou.txt wordlist.
- Users should avoid using predictable passwords and instead use passphrases with a mix of characters.

2. Salting:

- The salt (`$12345678`) added to the hash improves security against precomputed attacks, but isn't sufficient if the password is too common.

3. Mitigation Tips:

- Use stronger hashing algorithms like bcrypt, scrypt, or Argon2.
 - Implement multi-factor authentication (MFA).
 - Enforce strong password policies.
-

Interview Questions & Answers

1. What is John the Ripper used for?

John the Ripper is a password-cracking tool used to test password strength and recover plaintext passwords from hashes by using dictionary attacks, brute-force, or hybrid methods.

2. What is a password hash, and how is it different from encryption?

A password hash is a one-way function output used to securely store passwords. Unlike encryption, hashes are not meant to be reversed.

3. How does John identify the type of hash?

John auto-detects the hash type based on the format and structure of the hash string (e.g., `$1$...` indicates MD5-Crypt).

4. What is the purpose of salting?

Salting adds random data to a password before hashing to prevent precomputed attacks like rainbow tables and ensure each password hash is unique.

5. What are common hashing algorithms?

MD5, SHA1, SHA256, bcrypt, scrypt, and Argon2.

6. What's the difference between brute-force and dictionary attacks?

Brute-force tries all possible combinations, while dictionary attacks use a predefined list of likely passwords.

7. Why is rockyou.txt commonly used?

It contains millions of real leaked passwords from a past breach, making it highly effective in cracking weak passwords.

8. How can you protect against password cracking?

Use strong, unique passwords, salt hashes, choose secure hash algorithms, and enforce MFA.

9. What ethical concerns are there in password cracking?

Unauthorized password cracking violates privacy and legal policies. Ethical hacking should always be done with permission and for defensive purposes.

10. What happens if John fails to crack a hash?

If no matching word is found or brute force is incomplete, John will not return a password. This means the password may be too strong or not present in the wordlist.